

Paquete de cumplimiento para las mesas de validación

****Estado: BORRADOR TÉCNICO PARA VALIDACIÓN.** Ningún documento de este directorio está aprobado ni surte efecto hasta su validación formal.**

Fecha de elaboración: 17 de julio de 2026. Elaborado por: dirección técnica del proyecto VEC.

Contenido

Documento	Marco	Debe validarlo
Categorización ENS y declaración de aplicabilidad	ENS — RD 311/2022	Comité de Seguridad, responsable del sistema, Secretaría
Registro de actividades de tratamiento (RAT)	RGPD art. 30, LOPDGDD	Delegado de Protección de Datos, responsable del tratamiento
Evaluación de impacto (EIPD) del módulo de Bolsas	RGPD art. 35	Delegado de Protección de Datos, Comité de Seguridad, Servicio de Selección

Existe una versión imprimible conjunta en `paquete_validacion_cumplimiento.pdf` , regenerable con `generar_paquete.py` .

Método

Los tres documentos describen el sistema **tal y como está construido**, con la evidencia técnica citada (paquete de código, decisión DEC o documento del repositorio), y separan de forma expresa:

- lo ya implantado y verificable en el código;
- lo diseñado pero pendiente de componer (con su tarea Txx o dependencia);
- lo que solo las personas responsables pueden decidir o firmar.

Las propuestas de valoración (niveles ENS, plazos de conservación, juicio de proporcionalidad) son exactamente eso, propuestas: los huecos marcados `[pendiente de la mesa]` deben resolverse en la validación.

Relación con el resto del repositorio

- Auditoría de diseño y seguridad
- Cumplimiento y seguridad del portal
- Informe del comité de seguridad
- Estudios de requisitos de RRHH — los cuatro estudios con puerta NO-GO que acompañan a este paquete en las mesas.
- Registro de decisiones

ENS: propuesta de categorización y declaración de aplicabilidad

Borrador técnico para el Comité de Seguridad. RD 311/2022. Fecha: 17 de julio de 2026. No aprobado.

1. Alcance del sistema

Sistema de información ****Portal VEC — Ventanilla Electrónica del Empleado Público de la Diputación de Granada, con su módulo inicial de Gestión de Bolsas de trabajo**** (elaboración, llamamientos, contratos, reglas, consulta, documentos, comunicaciones y auditoría), su zona pública de consulta minimizada y su futura app de escritorio para personal técnico (clientes equivalentes por API, DEC-053). Incluye la persistencia PostgreSQL, la generación documental y los conectores previstos (Autofirma, Notific@, SIR).

Quedan fuera del alcance: los sistemas corporativos origen (RPT, nómina, directorio) que actúan como fuentes autoritativas, y la plataforma de correo/mensajería, que se integran mediante conectores con recibo.

2. Información tratada y servicios

- Datos identificativos de aspirantes y personal (nombre, DNI enmascarado en pantalla, contacto), méritos, experiencia, titulaciones y puntuaciones.
- Posibles **categorías especiales** (art. 9 RGPD): condición de discapacidad en turnos de reserva de bolsas. Su presencia condiciona la valoración de confidencialidad.
- Actos administrativos con efectos jurídicos: bases selladas, propuestas de llamamiento, contratos, resoluciones firmadas, notificaciones.
- Evidencias probatorias: auditoría encadenada, recibos, versiones de reglas.

3. Propuesta de valoración por dimensiones (Anexo I)

Dimensión	Nivel propuesto	Justificación
Confidencialidad (C)	Alto	Expedientes de RRHH con posible dato de discapacidad (art. 9); su revelación causaría perjuicio grave a los interesados y a la entidad. Si la mesa acota el dato de discapacidad a un tratamiento separado, puede razonarse Medio. [pendiente de la mesa]
Integridad (I)	Alto	La alteración del orden de una bolsa o de un baremo determina derechos de acceso al empleo público y vicia actos administrativos.
Trazabilidad (T)	Alto	El valor probatorio de llamamientos y resoluciones exige reconstruir quién hizo qué, cuándo y con qué versión de reglas.
Autenticidad (A)	Medio	Firma cualificada y sellado previstos; la suplantación se mitiga con identidad fuerte y atestación de decisiones.
Disponibilidad (D)	Medio	Una indisponibilidad de horas es asumible con procedimientos alternativos; los plazos administrativos dan margen.

Categoría global propuesta: ALTA (por C, I y T). La decisión formal de categorización corresponde al responsable del sistema a propuesta del Comité de Seguridad (art. 40 y Anexo I RD 311/2022).

4. Declaración de aplicabilidad (extracto de medidas relevantes)

Estado de las medidas del Anexo II con mayor peso para este sistema. La declaración completa medida a medida debe cerrarla el Comité con la categoría aprobada.

Marco organizativo (org)

Medida	Estado	Evidencia / pendiente
org.1 Política de seguridad	Pendiente	Debe aprobarla el órgano competente; insumo: este paquete
org.2 Normativa de seguridad	Parcial	Directrices técnicas vigentes en docs/portal_vec/auditoria_diseno_y_seguridad_2026-07-16.md y registro de decisiones
org.3 Procedimientos	Parcial	Puerta de calidad y flujo de dirección documentados; faltan procedimientos de explotación
org.4 Proceso de autorización	Diseñado	Autorización por caso de uso en el código; falta el circuito organizativo

Marco operacional (op)

Medida	Estado	Evidencia / pendiente
op.acc.1-2 Identificación y requisitos de acceso	Implantada en diseño	RBAC+ABAC de lista positiva cerrada, sin comodines (internal/vec); RLS en PostgreSQL
op.acc.5 Mecanismo de autenticación	Pendiente (S-03)	Certificado/Kerberos+mTLS diseñados (DEC-053); dependen de Sistemas; sin producción hasta su visto bueno
op.acc.6 Acceso local/remoto	Implantada	Allowlist CIDR sobre el socket, no falsificable desde cliente
op.exp.8 Registro de actividad	Parcial	Auditoría encadenada firmada probada; durabilidad en PostgreSQL pendiente (T12)
op.exp.10 Protección de los registros	Parcial	Cadena de firmas; custodia durable e inalterable pendiente (T12)
op.exp.4-6 Mantenimiento y vulnerabilidades	Implantada	CI con govulncheck , - race y puerta canónica en cada push; secret scanning y push protection en el repositorio
op.cont Continuidad	Pendiente	Copias ensayadas y prueba de recuperación (T12); plan de continuidad organizativo
op.mon Monitorización	Pendiente	Observabilidad centralizada sin desplegar

Medidas de protección (mp)

Medida	Estado	Evidencia / pendiente
mp.com.2 Protección de la confidencialidad (tránsito)	Pendiente	TLS productivo y proxy final dependen de Sistemas; perfil local ya cerrado a loopback
mp.info.3 Cifrado (reposo)	Parcial	Sobres AES-256-GCM en flujos sensibles; cifrado de columnas personales en PostgreSQL pendiente (T16)
mp.info.6 Limpieza y borrado	Pendiente	Ciclo de conservación y expurgo programado (T14) conforme al estudio de archivo
mp.si Soportes	Pendiente	Procedimiento organizativo de soportes y copias
mp.sw.1 Desarrollo seguro	Implantada	Hexagonal con fallo cerrado, tests 0,85/1, tope de ficheros DEC-051, revisión de dirección, datos reales nunca en desarrollo (sintéticos con test que lo vigila)
mp.info.9 Copias de seguridad	Pendiente	Ensayo de copia y recuperación (T12)

5. Plan de adecuación propuesto

1. Aprobar categorización y política (mesa/Comité). 2. Cerrar T12 (durabilidad probatoria y copias) y T13–T16 (medidas programables del paquete) — encoladas al agente. 3. TLS productivo, identidad real y KMS/HSM con Sistemas (S-03). 4. Declaración de aplicabilidad completa, auditoría de conformidad y publicación de la declaración de conformidad.

Registro de actividades de tratamiento (RAT) — módulo de Bolsas

****Borrador para el Delegado de Protección de Datos. Art. 30 RGPD y art. 31 LOPDGDD.**** Fecha: 17 de julio de 2026. No aprobado.

Responsable del tratamiento: **Diputación Provincial de Granada** [órgano concreto: pendiente de la mesa] .
Delegado de Protección de Datos: [designación vigente de la Diputación] . No se prevén transferencias internacionales en ninguna actividad.

A1 — Gestión de bolsas de empleo temporal (aspirantes)

Campo	Contenido
Fines	Constitución y gestión de bolsas: inscripción, baremación de méritos, orden de prelación, alegaciones y publicación de listados
Base jurídica	Art. 6.1.c y 6.1.e RGPD (TREBEP y normativa de selección); art. 9.2.b para la condición de discapacidad en turnos de reserva
Interesados	Personas aspirantes a las bolsas
Categorías de datos	Identificativos (nombre, DNI, contacto), académicos y profesionales (titulaciones, experiencia, méritos), puntuaciones; condición de discapacidad solo para el turno de reserva
Destinatarios	Órganos de selección y RRHH; publicación de listados con datos minimizados conforme a la normativa de transparencia (LO 3/2018, disp. ad. 7ª: identificación por iniciales/dígitos parciales)
Plazos de supresión	Propuesta: vigencia de la bolsa más los plazos de recurso y las tablas de valoración documental aplicables [pendiente de la mesa] ; expurgo programado (T14)
Medidas	Ver declaración ENS: minimización en pantalla (DNI enmascarado), RBAC+ABAC con RLS, auditoría encadenada, cifrado de flujos sensibles

A2 — Llamamientos y contratación temporal

Campo	Contenido
Fines	Cobertura de necesidades: propuesta calculada de personas según orden y reglas, comunicación fehaciente, aceptación/renuncia, contrato, cese y reincorporación
Base jurídica	Art. 6.1.c y 6.1.e RGPD; art. 6.1.b en la fase contractual
Interesados	Integrantes de bolsas llamados; personal temporal contratado
Categorías de datos	Identificativos y de contacto, posición y puntuación, disponibilidad y sus causas, condiciones del contrato
Destinatarios	RRHH, unidad de destino, Seguridad Social y AEAT (obligación legal), intervención
Plazos	Los del expediente de personal y sus tablas de valoración [pendiente de la mesa]
Medidas	La interfaz de revisión no recibe identidades (propuesta por secuencia y puntuación); decisión final humana y firmada; trazabilidad completa del acto

A3 — Portal del empleado (expediente propio)

Campo	Contenido
Fines	Acceso de cada empleado/a a su propio expediente, certificados y comunicaciones cuando se habiliten los módulos
Base jurídica	Art. 6.1.c y 6.1.e RGPD
Interesados	Personal de la Diputación
Categorías de datos	Expediente de personal: datos identificativos, administrativos, retributivos cuando proceda
Destinatarios	La propia persona interesada; ningún expediente de terceros se proyecta (frontera de privacidad verificada en el diseño del workspace)
Plazos	Los del expediente de personal
Medidas	Proyección resuelta en servidor por persona, ámbito y finalidad; endpoint cerrado (503) hasta componerse con identidad real

A4 — Seguridad, trazabilidad y auditoría

Campo	Contenido
Fines	Registro probatorio de actos y accesos; detección de uso indebido; cumplimiento ENS
Base jurídica	Art. 6.1.c y 6.1.e RGPD (obligaciones ENS); interés público en la integridad de los procesos selectivos
Interesados	Personal usuario del portal; aspirantes cuyos expedientes se consultan
Categorías de datos	Identidad del actor, rol, acto realizado, expediente afectado, finalidad declarada, momento, versión de reglas aplicada
Destinatarios	Órganos de control interno; jueces y tribunales cuando proceda
Plazos	Propuesta: los de prescripción de las responsabilidades que documentan [pendiente de la mesa]
Medidas	Cadena de auditoría firmada; registro de accesos con finalidad (T13); custodia durable (T12)

A5 — Consulta pública de convocatorias

Campo	Contenido
Fines	Publicidad de convocatorias y estado de bolsas a la ciudadanía
Base jurídica	Art. 6.1.e RGPD; obligaciones de publicidad activa
Datos	Sin datos personales: la superficie pública sirve datos minimizados y agregados; verificado en <code>internal/modules/bolsa/adapters/httppublico</code>
Medidas	Fuente sintética por defecto; salida minimizada en servidor

Nota de exactitud: las actividades A1–A3 describen capacidades del sistema; su alta efectiva en el RAT corporativo debe producirse cuando cada módulo entre en servicio con datos reales, momento que hoy no se ha producido (no hay producción ni datos reales cargados).

Evaluación de impacto en protección de datos (EIPD) — módulo de Bolsas

Borrador para consulta al Delegado de Protección de Datos. Art. 35 RGPD. Fecha: 17 de julio de 2026. No aprobado. Metodología: guía de la AEPD.

1. Necesidad de la evaluación

La EIPD procede porque el tratamiento reúne varios criterios del art. 35.3 y de las listas de la AEPD:

- **evaluación sistemática** de aspectos personales (baremación de méritos) que produce efectos jurídicos (orden de acceso al empleo público);
- **gran escala** a nivel provincial (cientos de integrantes por bolsa);
- posible tratamiento de **categorías especiales** (discapacidad en turnos de reserva);
- colectivo en situación de asimetría (aspirantes frente a administración).

2. Descripción sistemática del tratamiento

Ciclo: inscripción → baremación conforme a bases selladas → listados → llamamiento (propuesta calculada en servidor → revisión humana → acto firmado → comunicación fehaciente) → contrato/cese → archivo.

Flujos técnicos relevantes, tal y como están contruidos:

- Las **bases y reglas** de cada bolsa se publican como versiones inmutables con huella criptográfica; todo cálculo cita su versión exacta.
- La **propuesta de llamamiento** se calcula íntegramente en servidor y se presenta a la persona técnica **sin identidades** (secuencia, resultado, puntuación, regla y fundamento); la relación con las personas queda custodiada en servidor bajo autorización.
- La **zona pública** solo sirve datos minimizados; los listados usan identificación reducida conforme a la disposición adicional 7ª LOPDGDD.
- Los accesos internos se autorizan por caso de uso (lista positiva, RLS) y quedan trazados con finalidad.

3. Decisiones automatizadas (art. 22 RGPD)

El sistema ****no adopta decisiones basadas únicamente en tratamiento automatizado****: la propuesta del motor es un insumo; la selección la revisa y la firma una persona con competencia, y el acto resultante es recurrible por las vías administrativas ordinarias. Este diseño debe preservarse: la prohibición de "aceptar propuestas sin revisión" es un requisito, no una opción de interfaz.

4. Necesidad y proporcionalidad

- **Idoneidad**: la gestión electrónica con reglas selladas reduce el error y la arbitrariedad frente al procedimiento manual.
- **Minimización**: verificada por diseño (identidades fuera de las pantallas de revisión; público minimizado; demo sintética separada por doble llave con test que impide su fuga al modo normal).

- **Limitación de finalidad:** cada acceso declara finalidad y queda registrado (T13); los catálogos impiden usos fuera de los previstos.
- **Exactitud:** fuentes autoritativas declaradas y versionadas; cálculo con aritmética exacta (sin flotantes) y redondeos configurados por bases.

5. Análisis de riesgos para derechos y libertades

Riesgo	Mitigación implantada	Residual y plan
Acceso indebido a expedientes por personal interno	RBAC+ABAC lista positiva, RLS, finalidad declarada, auditoría encadenada	Medio-bajo; baja a bajo con registro de accesos durable (T12/T13)
Exfiltración del censo de una bolsa	Las consultas globales no descargan censos (contrato del panel lo rechaza); propuestas sin identidad	Bajo
Alteración del orden o del baremo	Versiones selladas con huella, atestación de decisiones, cadena firmada	Bajo; auditoría durable pendiente (T12)
Suplantación de identidad interna	Diseñada identidad fuerte (certificado/Kerberos+mTLS); allowlist de red	Medio mientras no se componga (S-03): sin producción hasta el visto bueno de Sistemas
Pérdida de trazabilidad probatoria	Cadena firmada en memoria	Medio: T12 la lleva a PostgreSQL con copias ensayadas
Reidentificación en demostraciones	Datos 100 % sintéticos, doble llave servidor+URL, test anti-fuga	Bajo
Brecha de confidencialidad en tránsito	Perfil actual solo loopback/red interna	TLS productivo con Sistemas antes de piloto
Conservación excesiva	Estudio de archivo elaborado	Expurgo programado (T14) y plazos a fijar por la mesa

6. Medidas previstas y plan

Programables (encoladas al agente): T12 durabilidad probatoria y copias ensayadas; T13 registro de accesos con finalidad; T14 conservación y expurgo; T15 atención de derechos (acceso, rectificación, supresión, oposición, limitación) con evidencia; T16 cifrado en reposo de columnas personales con gestión de claves.

Organizativas (mesas): designación de roles ENS, política de seguridad, plazos de conservación, procedimiento de brechas (notificación AEPD 72 h, CCN-CERT), formación del personal usuario.

7. Conclusión provisional

Con las medidas implantadas, el tratamiento es ****viable en demostración con datos sintéticos (situación actual). Para un piloto con datos reales**** se consideran condiciones previas: T12, T13 y TLS productivo, más la validación de este documento por el DPD. Para **producción:** identidad real (S-03), medidas T14-T16, categorización ENS aprobada y esta EIPD formalizada con el dictamen del DPD.

[Dictamen del DPD: pendiente] · [Aprobación del responsable: pendiente]